

Cybersecurity Incident Response Plan

Ransomware Simulation, Detection & Recovery Procedures, and Staff Training Program

Prepared by Jawad Ahmed | Cybersecurity Intern | July 2026

Document Purpose

This document is a working incident response (IR) plan built for Internee.pk. It explains, step by step, how to detect a cybersecurity incident, contain and remove the threat, recover normal operations, and learn from what happened. It also includes a ransomware attack simulation (a safe, tabletop-style walkthrough, not a real attack) mapped to the MITRE ATT&CK framework, plus a training outline for staff. Each section explains what the step is, why it matters, and exactly how to do it, so it can be followed by someone doing this for the first time.

1. Objective and Scope

The objective is to give Internee.pk a repeatable, documented process for handling security incidents — from the moment something looks wrong to the point normal business is fully restored and the team has captured lessons for next time.

1.1 What 'Incident Response' Means

Incident response is the organized approach an organization takes to prepare for, detect, contain, and recover from a security breach or cyberattack. Instead of reacting randomly to an incident, IR follows a defined lifecycle so nothing important is missed under pressure — evidence isn't destroyed, stakeholders are informed, and the same failure doesn't repeat.

1.2 In Scope

- Detection and triage procedures for suspicious activity on endpoints, servers, and network devices.
- Containment, eradication, and recovery procedures, with ransomware as the primary scenario.
- A tabletop ransomware simulation with a MITRE ATT&CK mapping and a documented Proof-of-Concept (PoC) style incident report.
- A staff training and awareness plan covering emergency response protocols.

1.3 Out of Scope

- Physical security incidents (covered under a separate physical security policy).
- Legal/regulatory breach-notification drafting (should involve legal counsel separately).

2. The Incident Response Framework

This plan follows the widely used NIST SP 800-61 lifecycle, which breaks IR into four phases. Understanding these phases matters because each one has a different goal — trying to 'recover' before you've properly 'contained' a ransomware infection, for example, is how organizations get re-encrypted.

2.1 The Four Phases

Preparation: Everything done before an incident happens: tools, logging, backups, roles, and training. This is the phase that determines how well the other three go.

Detection & Analysis: Spotting that something abnormal is happening, then confirming whether it is actually a security incident (true positive) or a false alarm.

Containment, Eradication & Recovery: Stopping the threat from spreading, removing it completely, and safely restoring affected systems to normal operation.

Post-Incident Activity: Reviewing what happened, documenting lessons learned, and updating defenses so the same attack path doesn't work twice.

3. Phase 1 — Preparation

What this is: the groundwork that makes the rest of the plan possible. Why it matters: an IR plan is useless if there are no backups to restore from, no logs to investigate with, and no one who knows their role. Below is what to have in place, and how to set it up.

1. Maintain an up-to-date asset inventory. Doable: keep a simple spreadsheet or CMDB entry for every server, workstation, and critical application, including owner and criticality (low/medium/high).
2. Enforce offline or immutable backups. Doable: schedule daily backups of critical data to storage that ransomware cannot reach or encrypt (e.g., an offsite location, or a backup target with immutability/versioning enabled). Test restoring from backup at least quarterly.
3. Deploy centralized logging (SIEM). Doable: forward logs from endpoints (Sysmon/EDR), firewalls, and servers to a central log collector so nothing is lost if a single machine is compromised.
4. Define IR roles in advance. Doable: name an Incident Response Lead, a Communications Lead, and at least one Technical/Forensics Analyst — even if these are part-time roles held by existing staff.
5. Pre-approve a containment toolkit. Doable: confirm in advance that staff have the access rights needed to isolate a host from the network (e.g., switch port disable, EDR network-isolation feature) without waiting on a change-approval process during a live incident.
6. Establish an incident severity matrix. Doable: agree beforehand on what counts as Low/Medium/High/Critical severity (e.g., a single infected laptop vs. domain-controller compromise) so triage decisions are fast and consistent.

4. Phase 2 — Threat Detection

What this is: the process of noticing that something is wrong and figuring out whether it's a genuine security incident. Why it matters: the earlier a threat is detected, the smaller the blast radius — ransomware that is caught during initial execution is far cheaper to deal with than ransomware caught after it has encrypted a file server.

4.1 Detection Sources

- SIEM correlation alerts (e.g., unusual login times, impossible travel, privilege escalation).
- EDR/antivirus behavioral alerts (e.g., a process rapidly renaming files, disabling shadow copies).

- Network-based indicators (unusual outbound traffic volume, connections to known-bad IPs/domains, DNS tunneling patterns).
- User reports (an employee noticing files renamed with an unfamiliar extension, or a ransom note appearing on the desktop).

4.2 Step-by-Step Detection & Triage Procedure

7. Receive the alert or report. Doable: log it immediately in the ticketing system with a timestamp — this becomes the first line of the incident timeline.
8. Perform initial validation. Doable: check whether the alert correlates with other signals (e.g., does the 'suspicious PowerShell' alert coincide with a phishing email received by the same user 10 minutes earlier?).
9. Classify true positive vs. false positive. Doable: use EDR process-tree view and recent file-system activity to confirm malicious behavior rather than a legitimate admin script.
10. Assign severity using the pre-agreed matrix. Doable: e.g., 'single endpoint, no lateral movement observed' = Medium; 'file server encryption in progress' = Critical.
11. Escalate to the IR Lead if Medium or above. Doable: use a defined escalation channel (phone call plus ticket update, not just email) so a critical incident is never missed due to inbox overload.

5. Phase 3 — Mitigation (Containment & Eradication)

What this is: stopping the incident from getting worse, then removing the attacker's foothold entirely. Why it matters: contain first, then eradicate — removing malware before isolating the host can tip off the attacker or let the threat spread further while you're cleaning up.

5.1 Containment

12. Isolate the affected host from the network immediately (disable switch port or use EDR network isolation) while keeping the machine powered on to preserve volatile evidence.
13. Disable or reset compromised credentials. Doable: force a password reset for the affected account(s) and review for any newly created accounts or added privileges.
14. Block known indicators of compromise (IOCs) at the firewall/proxy — malicious IPs, domains, and file hashes identified during triage.
15. Preserve evidence before making further changes. Doable: capture a memory image and/or disk image of the affected host for forensic analysis before wiping anything.

5.2 Eradication

16. Identify and remove the root cause. Doable: locate the initial infection vector (e.g., malicious attachment, exploited vulnerability) and confirm all persistence mechanisms (scheduled tasks, registry run keys, new services) are removed.
17. Patch or reconfigure the exploited weakness. Doable: apply the missing security update, disable the vulnerable service, or tighten the misconfigured permission that allowed initial access.
18. Scan all systems that the compromised host had access to. Doable: run a full EDR/AV scan across any server or share the account could reach, to rule out lateral spread.

6. Phase 4 — Recovery

What this is: bringing systems back into normal production use safely. Why it matters: restoring too early — before the root cause is fixed — risks immediate re-infection, which is one of the most common ransomware recovery mistakes.

19. Rebuild affected systems from a known-clean image or reinstall from scratch rather than trusting a 'cleaned' but previously infected machine.
20. Restore data from the most recent clean backup, verifying backup integrity and confirming it predates the compromise.
21. Reconnect systems to the network in stages, monitoring closely for any recurrence of the original indicators.
22. Reset all potentially exposed credentials, including service accounts and any credentials cached on the affected host.
23. Confirm full business functionality with the affected department before formally closing the incident.

7. Phase 5 — Post-Incident Activity (Lessons Learned)

What this is: a structured review conducted after the incident is resolved. Why it matters: without this step, organizations fix the immediate symptom but leave the underlying gap (e.g., no MFA, no email filtering) open for the next attacker.

- Hold a lessons-learned meeting within 5–10 business days of resolution, including everyone who was part of the response.
- Document a timeline: what happened, when it was detected, what actions were taken, and total time to containment and recovery.
- Identify at least one concrete control improvement (e.g., 'enable MFA on all remote-access accounts') and assign an owner and deadline.
- Update the IR plan itself if any step was unclear or slow during the real response.

8. Ransomware Attack Simulation (Tabletop Exercise)

What this is: a safe, contained simulation used to test the plan above without any real malware or real damage. It exercises the same detection-to-recovery workflow using a benign test script and an isolated lab environment (the same type of Kali Linux / isolated VM lab already used for the MS17-010 exercise), so the team practices decision-making under realistic pressure. Why it matters: an IR plan that has never been rehearsed usually falls apart during a real incident — people don't know who to call, how to isolate a host, or where the backups actually are.

8.1 Simulation Setup

- Use an isolated lab network with no connection to production systems or the internet, matching the existing internship lab environment.
- Use a benign, purpose-built test script that only renames/moves files inside a dedicated test folder to imitate ransomware behavior — never a real ransomware sample.
- Inform all lab participants in advance that this is a scheduled exercise (a 'no-notice' variant can be run later once the team is experienced).
- Have the SIEM/EDR test environment actively logging before the exercise starts, so the detection phase produces real alerts to analyze.

8.2 MITRE ATT&CK Mapping for the Simulated Attack Chain

Mapping the simulated attack to MITRE ATT&CK gives the exercise a recognized, industry-standard structure and makes it easy to check that each stage produced a detectable signal.

Attack Stage	MITRE ATT&CK Technique	Ransomware Simulation Action	Detection Data Source
Initial Access	T1566 – Phishing	Simulated malicious macro-enabled document delivered to a test mailbox	Email gateway logs, EDR process creation events
Execution	T1059 – Command and Scripting Interpreter	PowerShell dropper launched from the document	PowerShell script block logging, Sysmon Event ID 1
Persistence	T1547 – Boot or Logon Autostart	Registry Run key added by test payload	Registry modification logs, Sysmon Event ID 13
Defense Evasion	T1027 – Obfuscated Files	Encoded PowerShell command used to avoid signature match	AMSI logs, EDR behavioural alerts
Impact	T1486 – Data Encrypted for Impact	Test files in an isolated folder encrypted by a benign simulation script	File integrity monitoring, mass file-rename/write alerts
Exfiltration	T1041 – Exfiltration Over C2 Channel	Simulated outbound transfer of a dummy archive to an external test endpoint	Firewall/proxy logs, DLP alerts, NetFlow anomalies

8.3 Step-by-Step Incident Handling Walkthrough

24. Kick off: the test script executes in the isolated lab, simulating file encryption on TEST-HOST-01. Record the exact start time.
25. Detection: confirm the SIEM/EDR generates an alert for the mass file-rename behavior (this validates Phase 2 detection sources actually work).
26. Triage: the on-duty analyst validates the alert and assigns severity using the matrix from Section 4.2 — treat this as Critical since it resembles active ransomware.
27. Escalation: notify the IR Lead per the defined escalation channel; start the incident log (see template in 8.4).
28. Containment: isolate TEST-HOST-01 from the lab network using the same isolation method defined in Section 5.1.
29. Evidence capture: image the test host's memory/disk before any cleanup, exactly as it would be done in a real incident.
30. Eradication: identify the 'root cause' (the test script's entry point) and confirm no persistence mechanism remains.
31. Recovery: restore the test files from backup and reconnect the host to the lab network in stages, watching for recurrence.
32. Debrief: hold a short lessons-learned discussion immediately after, while the exercise is still fresh, and record at least one improvement action.

8.4 Incident Log Template (fill in during the exercise)

Keeping a live, timestamped log is what turns an exercise into a usable PoC report — it's the evidence that each phase of the plan was actually followed, and it's exactly the format used for the MS17-010 PoC submission.

Timestamp	Event / Action Taken	Performed By	Evidence / Reference
T+0 min	Alert triggered: mass file rename detected on TEST-HOST-01	SIEM (automated)	Alert ID / screenshot
T+5 min	Analyst validates alert, confirms suspicious process tree	Tier-1 Analyst	EDR console export
T+10 min	Incident declared, IR lead notified, severity assigned	Tier-1 Analyst / IR Lead	Ticket #IR-XXXX
T+15 min	Affected host isolated from network (VLAN quarantine)	IR Lead	Isolation confirmation log
T+30 min	Volatile memory and disk image captured for forensics	Forensics Analyst	Image hash values

8.5 Structure for the Final PoC / Exercise Report

- Executive summary: one paragraph on what was simulated and the outcome.

- Scope and environment: lab setup, tools used, and confirmation no production system was touched.
- MITRE ATT&CK mapping table (Section 8.2, reused directly).
- Full incident timeline (from the log in Section 8.4).
- Screenshots/evidence of alerts, isolation actions, and successful recovery.
- Findings and recommended improvements (feeds directly into Section 7, Post-Incident Activity).

9. Staff Training Program

What this is: a plan to make sure everyone at Internee.pk — not just the security team — knows what to do when something looks wrong. Why it matters: most real-world ransomware incidents start with a single employee action (opening an attachment, entering credentials on a fake page); trained staff are a detection layer, not just a risk.

9.1 Training Modules

Module 1 — Security Awareness Basics: Recognizing phishing emails, suspicious links, and social engineering attempts. Delivered to all staff, refreshed every 6 months.

Module 2 — Incident Reporting Procedure: Exactly who to contact and how (e.g., a dedicated #security-incident channel or hotline) the moment something looks wrong — emphasizing that reporting fast, even if it turns out to be a false alarm, is always the right call.

Module 3 — Technical Responder Training: For IT/security staff: hands-on practice with the isolation, evidence-capture, and log-review steps in Sections 4–6, culminating in the tabletop exercise in Section 8.

Module 4 — Executive/Communications Briefing: For leadership: how incidents are escalated, what decisions they may be asked to make (e.g., paying a ransom is never recommended and should involve legal counsel), and how external communications are handled.

9.2 Suggested Training Schedule

33. Month 1: Module 1 for all staff (30-minute session) + Module 2 rollout with reporting channel setup.
34. Month 2: Module 3 hands-on lab for IT/security staff, including a walkthrough of Sections 4–6 of this plan.
35. Month 3: Full tabletop ransomware exercise (Section 8) with technical staff, observed by an executive sponsor.
36. Ongoing: quarterly phishing-simulation tests for all staff, with results feeding back into Module 1 refreshers.

9.3 Measuring Training Effectiveness

- Track phishing-simulation click rates over time (target: decreasing trend).
- Track mean time to report a suspicious event after Module 2 rollout.
- Track tabletop-exercise completion time for each IR phase, compared exercise to exercise.

10. Data Sources and References

These are the reference materials this plan draws its structure and attack-technique detail from.

- MITRE ATT&CK Framework — used for the attack-technique mapping in Section 8.2 (attack.mitre.org).
- NIST SP 800-61 (Computer Security Incident Handling Guide) — source of the four-phase lifecycle used throughout this plan.
- Internee.pk internal cybersecurity breach case studies — dashboard/assignments repository, for real-world scenario grounding.

11. Summary

This plan gives Internee.pk a complete, rehearsed path from 'something looks wrong' to 'fully recovered and improved,' with a concrete ransomware tabletop exercise mapped to MITRE ATT&CK and a training track so the whole organization — not only IT — is part of the defense.